

OPERATIONS & COMPLIANCE

HIPAA, Privacy & Marketing Compliance

Safeguards, breach response, before-and-after images, testimonials and advertising claims

DOCUMENT OPS-005	VERSION 1.0	EFFECTIVE January 2026	REVIEW CYCLE Annual
APPLIES TO All staff, marketing personnel and vendors	OWNER Medical Director	CLASSIFICATION Confidential	SUPERSEDES All prior versions

1 Purpose & Scope

Privacy and marketing are combined in one protocol because med spas break both in the same place: a before-and-after posted to social media. This document covers the safeguards protecting patient information, the response when it is disclosed improperly, and the standards governing how treatments and results are advertised.

TWO REGULATORS, ONE POST

An unauthorized before-and-after is a privacy problem. An exaggerated claim about what the treatment achieved is an advertising problem, and in some states a licensing problem too. The same post can be all three.

2 Safeguards

Category	Requirements
Administrative	Named privacy officer. Documented policies. Workforce training at hire and annually. Access granted on a minimum-necessary basis. Access revoked on the day someone leaves. Periodic risk assessment with findings acted upon.
Physical	Screens not visible from waiting or public areas. Charts and paper records secured when unattended. Treatment room doors closed during consultations. Secure destruction of paper containing patient information.
Technical	Individual logins — never shared. Automatic screen lock. Encryption of devices and backups. Secure messaging for anything containing patient information. Audit logging enabled and periodically reviewed.
Vendors	Business associate agreements in place with every vendor that touches patient information: practice management, EMR, billing, cloud storage, transcription, marketing platforms handling patient lists.

The everyday failures

- Discussing a patient where other patients can hear — reception, corridors, the treatment room next door.
- Patient photographs taken and stored on personal phones.
- Text messages and direct messages containing clinical information from personal accounts.
- Responding to an online review in a way that confirms the person was a patient.
- Shared logins that make audit logs meaningless.
- Sign-in sheets and appointment screens visible to other patients.

RESPONDING TO ONLINE REVIEWS

Replying to a negative review by explaining what actually happened during the visit discloses that the person was a patient and discloses clinical detail. Even confirming someone was treated is a disclosure. Respond generically, invite the person to make contact privately, and never engage with the clinical specifics in public — however unfair the review is.

3 Photography & Image Use

Three separate permissions, captured separately, at different times. Bundling them into one signature at intake is the most common error in the field.

Permission	Covers	Notes
Clinical photography	Taking and storing images as part of the medical record.	Part of the clinical record; retained per the record retention schedule.
Internal or educational use	Use in staff training, case review or professional education.	Separate authorization. Specify whether identifying features are shown.
Marketing and publication	Website, social media, advertising, print, third-party platforms.	Separate written authorization. Must state where images may appear, whether the face is shown, and that the patient may revoke it.

- ☐ Clinical images captured on practice-owned devices only, never personal phones.
- ☐ Images stored in the clinical record system, not in a camera roll or a shared drive.
- ☐ Marketing authorization is specific, written, dated and separately signed.
- ☐ Revocation honoured promptly, including removal from platforms where practical, and the request and action documented.
- ☐ Cropping a face out does not make an image de-identified if tattoos, jewelry, scars or background make the person recognizable.
- ☐ Images of minors require parental or guardian authorization, handled with particular care.
- ☐ Authorization records retained for the same period as the clinical record.

4 Advertising & Claims

- Claims must be truthful and substantiated. Results shown must be typical, or the atypical nature must be clearly disclosed.
- Before-and-after images must be unretouched and taken under comparable conditions — same lighting, distance, angle and posing. Retouched comparison images are deceptive.
- Do not guarantee results, and avoid superlatives that cannot be substantiated.
- Disclose material connections in any endorsement — free or discounted treatment in exchange for a post must be disclosed clearly and conspicuously.
- Testimonials must come from real patients, be genuinely held, and never be fabricated, incentivized without disclosure, or edited to change their meaning.
- Off-label uses must not be advertised as approved indications.

- Provider credentials must be represented accurately — title, licensure and specialty. Several states regulate the use of the word 'doctor' and specialty descriptors in aesthetic advertising.
- Pricing and package terms stated clearly, including what is excluded.

FABRICATED REVIEWS

Writing your own testimonials, incentivizing reviews without disclosure, or suppressing negative ones carries direct regulatory exposure — and it is a strange risk to take on a business whose product is credibility. If you do not have real testimonials yet, publish none.

5 Breach Response

- 1 **Contain immediately.** Revoke access, remove the post, recover the device, disable the account — whatever stops further disclosure.
- 2 **Notify the privacy officer and medical director** the same day.
- 3 **Preserve evidence.** Screenshots, logs, timestamps. Do not delete the trail while removing the content.
- 4 **Assess.** What information, how many individuals, who received it, was it encrypted, and has it been mitigated. Document the assessment and its reasoning regardless of the conclusion.
- 5 **Notify** affected individuals and authorities where required, within the applicable timeframes. Timeframes are strict and start early.
- 6 **Document everything** — the incident, the assessment, the decision, the notifications and the dates.
- 7 **Remediate.** Address the root cause and record the corrective action, not just the individual incident.
- 8 **Retrain** where the cause was a workforce action, and record the retraining.

DOCUMENT THE ASSESSMENT EITHER WAY

If you assess an incident and conclude notification is not required, that reasoning must be written down and retained. An undocumented decision not to notify looks identical to never having considered it.

6 Quick Reference

QUICK REFERENCE CARD

Before you post

1. **Separate written marketing authorization** on file — not the intake form.

2. **Practice-owned device** and practice-owned storage only.

3. **Unretouched**, same lighting, distance and angle.

4. **Results typical**, or the atypical nature clearly disclosed.

5. **Material connections disclosed** in any endorsement.

6. **Never respond to a review** with clinical detail.

7. **Revocation honoured promptly** and documented.

8. **Breach: contain, notify the privacy officer same day, preserve evidence.**

Print, laminate and post at the point of care

7 Medical Director Authorization

This protocol is adopted as a standing order for the practice named below. By signing, the medical director confirms the protocol has been reviewed against current clinical guidance, applicable state scope-of-practice rules, and the training level of the staff authorized to perform it.

PRACTICE NAME

LOCATION / SITE

MEDICAL DIRECTOR — PRINTED NAME & CREDENTIALS

LICENSE NUMBER & STATE

SIGNATURE

DATE ADOPTED / NEXT REVIEW DATE

Template notice. This document is an editable template provided for educational and operational guidance. It is not legal advice, does not constitute a physician–patient relationship, and does not guarantee regulatory compliance or the outcome of any inspection. Drug doses, concentrations and device settings must be verified against current manufacturer labeling and prevailing clinical guidance before use. A licensed medical director must review, customize and sign this protocol before it is placed into service, and must confirm that every task assigned within it falls inside the scope of practice of the personnel performing it in your state.

© MedSpa Standards. Licensed for use within the purchasing practice only. Redistribution or resale is prohibited.

OPS-005 HIPAA, Privacy & Marketing Compliance — MedSpa Standards v1.0 · January 2026

Page 4 of 4